Information Assurance and Security – ACIT4630

Iman Anooshehpour
Week 6

BRITISH COLUMBIA
INSTITUTE TECHNOLOGY

BCIT™

Learning Objectives

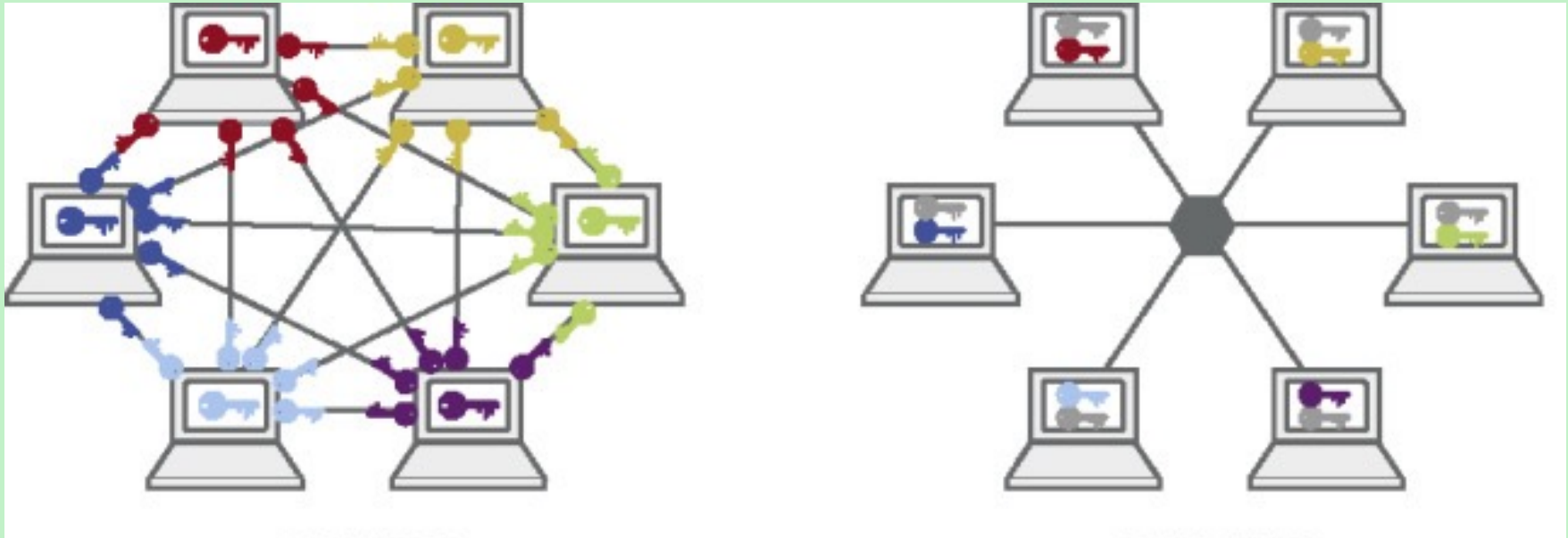
- How many keys are needed in a network?
- Digital Signature Verification + Man In The Middle Attack
- Public Key Infrastructure
- Explain the difference between Identification, Authentication, and Authorization
- List different kinds of authentications factors and examples for each
- Compare and contrast different kinds of password attacks
- Explain how RockYou data breach made password hacking much easier
- Perform different online and offline attacks on Kali Linux

Keys needed in a network

- The total number of unique **symmetric** cryptography keys required for every pair of n users (or nodes) in a network to communicate securely
- $Total\ Keys = \frac{n(n-1)}{2}$

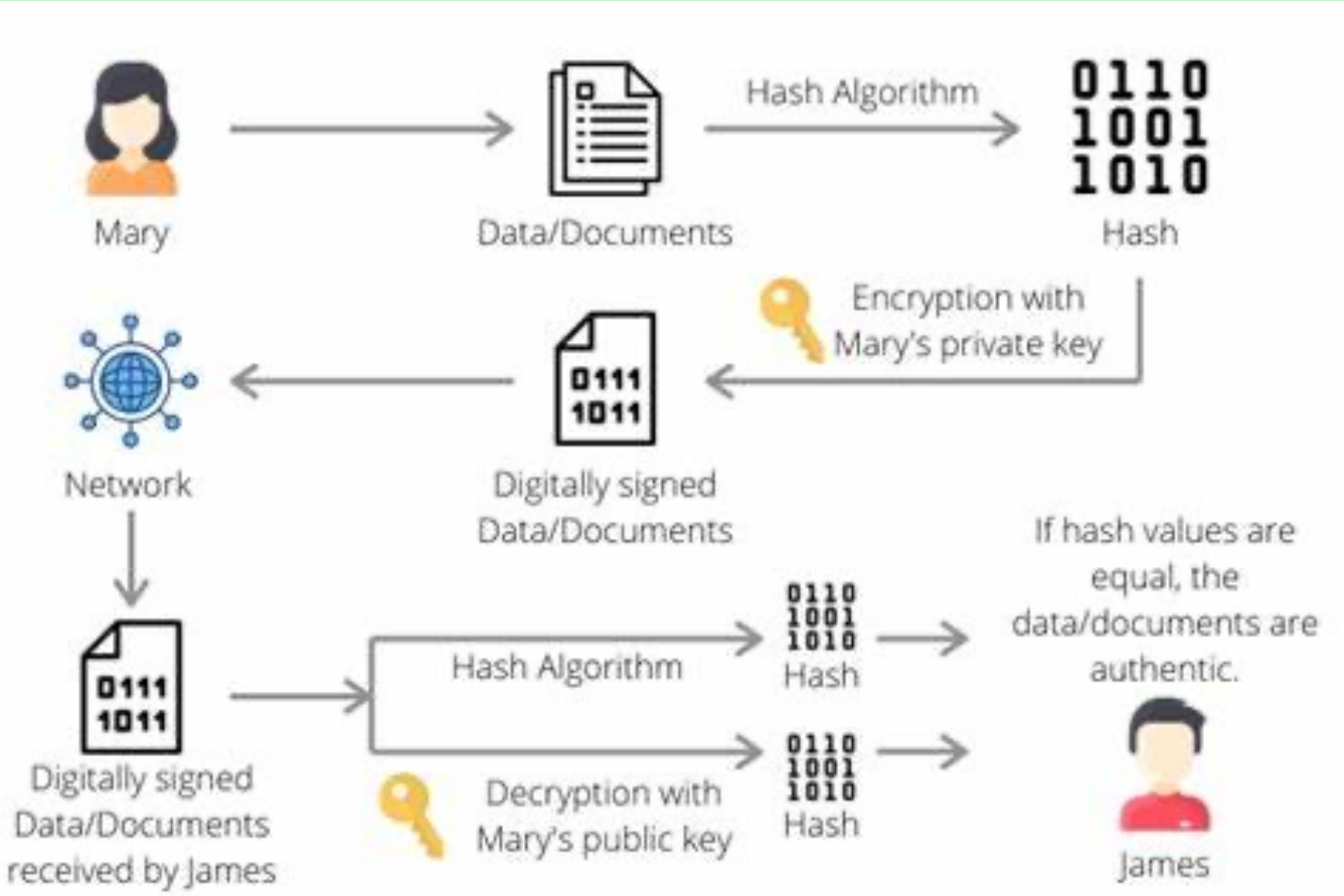
The total number of unique **asymmetric** cryptography keys required for every pair of n users (or nodes) in a network to communicate securely

$$Total\ Keys = 2n$$



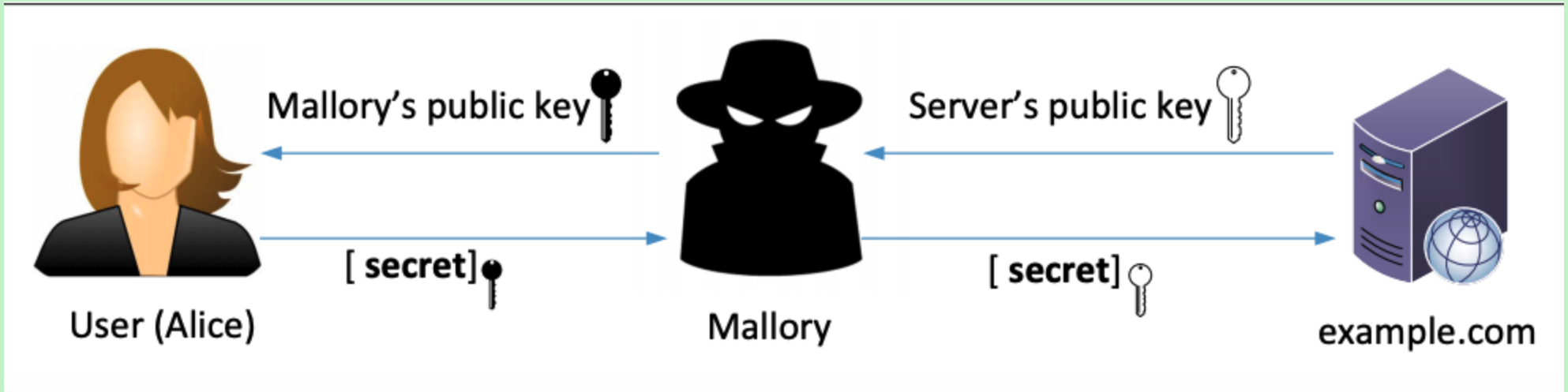
Digital Signature Verification

- Digital signatures provide authenticity, integrity, and non-repudiation
- Signer's private key used for **creating** the signature
- Signer's public key used for **verifying** the signature



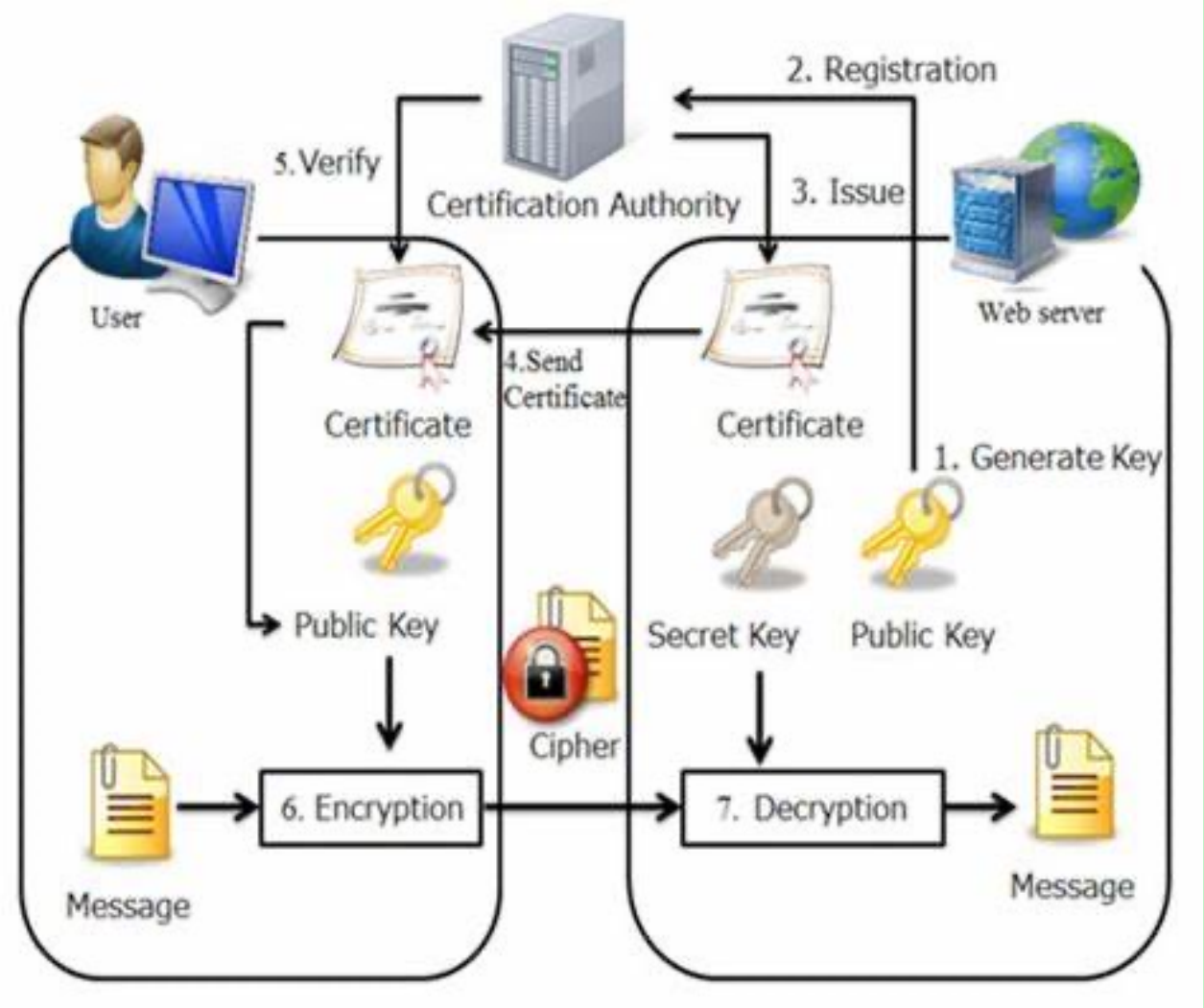
MITM Attack – Public Key Encryption

- In asymmetric cryptography the encrypted message can only be decrypted by the recipient's private key
- What if the attacker manipulates the public key during key exchange?



Public Key Infrastructure

- Trusted Certificate Authorities (CA)
  - Verifies identity of users and their public key
  - Issues a digitally signed digital (public key) X.509 certificates



Summary of Identifying OIDs

Validation Type	OID (Certificate Policies)	Organization Details Present?
DV (Domain Validation)	`2.23.140.1.2.1`	❌ No (Only CN)
OV (Organization Validation)	`2.23.140.1.2.2`	✅ Yes
EV (Extended Validation)	`2.23.140.1.1`	✅ Yes (Includes Business Category)

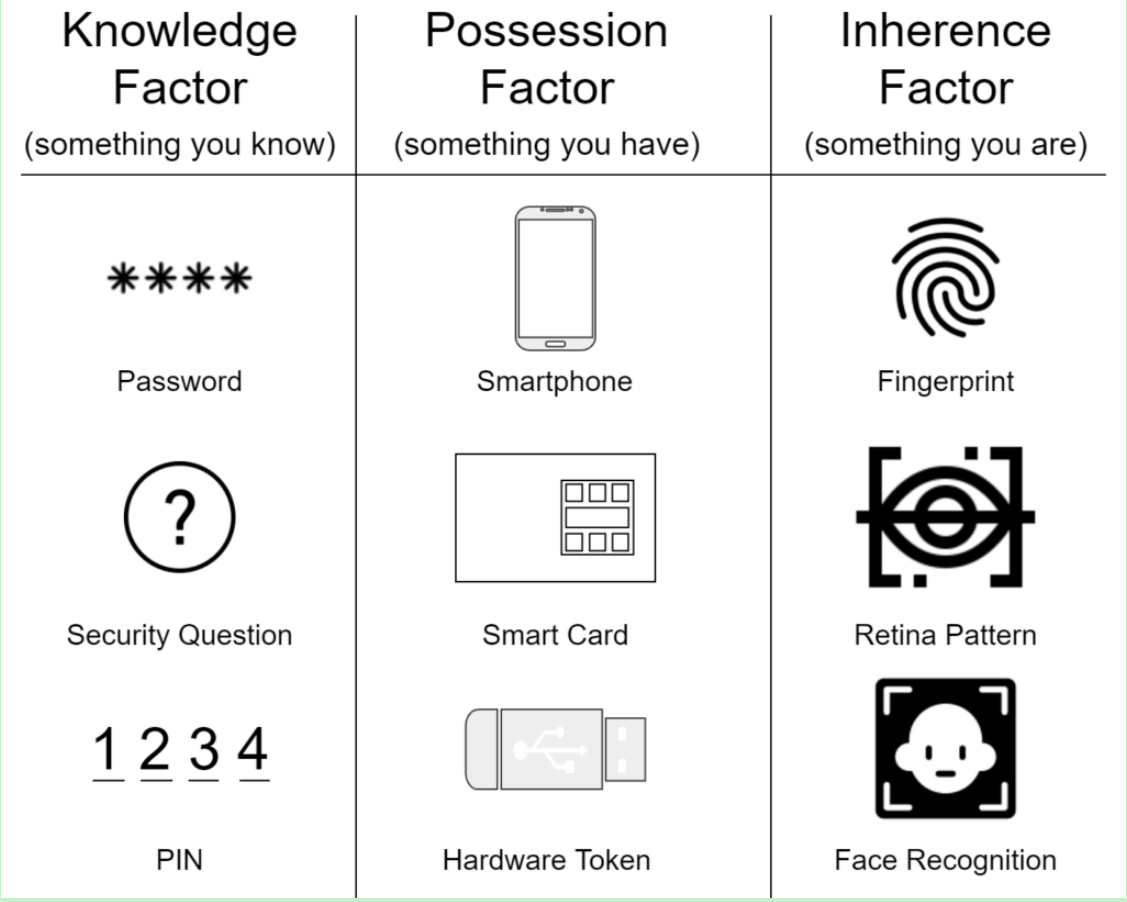
Would you like a script to extract this info automatically? 🚀

Identification

- What is an example of valid authorization without identification and authentication?
- What is an identity and access management (IAM) system?

Authentication factors

- Knowledge Factor – something you **know**, e.g., password
- Possession Factor – something you **have**, e.g., mobile phone
- Inherence Factor – something you **are**, e.g., fingerprint
- What are the risks associated with authentication factors?
- What is considered as multi-factor authentication?



Password Attacks

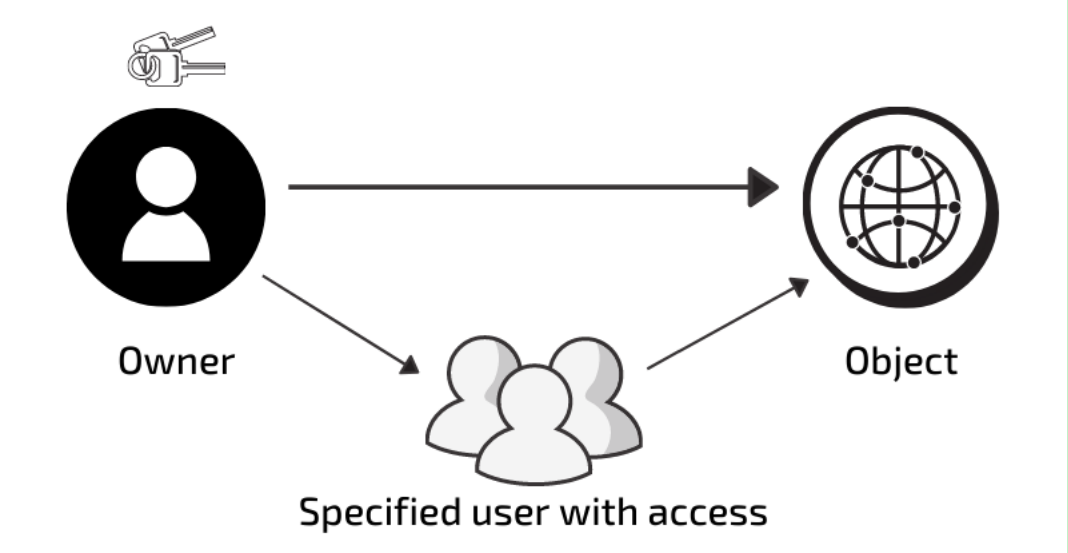
- Brute-force attack – Try all character combinations until the password is found.
- Dictionary attack – Prioritize words in a dictionary over random words.
- Password spraying – Dictionary attacks that employ frequently used passwords .
- Credential stuffing – Reuse stolen credentials across different services.
- Rainbow table attacks – Use precomputed hash tables to crack password hashes.

RockYou Hack (2009)

- 32 million plaintext passwords compromised
- The hacker used a 10-year-old SQL vulnerability to gain access to the database
- What did we learn from the revealed password?
  - About a third are less than six characters
  - Half are vulnerable to dictionary attacks.
  - The most common passwords
  - Users' thinking patterns for creating a password

Authorization

- Least privilege and separation of duties rules
- What is privilege creep and how to avoid it?
- Mandatory access controls (MAC) (e.g., SELinux)
- Discretionary access controls (DAC)



About Next Week Class (week7)

There will be:

- No Slides
- No Lab
- Quiz 6 (Make sure to read the Reading Material)
- Presentations (2+)
- Mid-term Review (some sample questions)

- Reminder! **week 8** is exam week and there will be **no class**